

Lab: OS command injection, simple case

Lab: OS command injection, simple case

APPRENTICE



LAB



Solved



This lab contains an OS command injection vulnerability in the product stock checker.

The application executes a shell command containing user-supplied product and store IDs, and returns the raw output from the command in its response.

To solve the lab, execute the `whoami` command to determine the name of the current user.



ACCESS THE LAB

to solve this lab

we use a burpsuite interception and we catch the requests

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS an... Pro version only Filter on ?

#	Host	Met...	URL	Para...	Edited	Status c...	Leng...	MIME ...
13	https://app.nackined...	GET	/time=1787266005/36			200	14298	HTML
14	https://ctc.insa.gov.et	GET	/api/roles/student/yearb...			200	1077	JSON
15	https://ctc.insa.gov.et	GET	/api/roles/student/tasks			200	1384...	JSON
16	https://ctc.insa.gov.et	GET	/api/roles/announcement...			200	965	JSON
17	https://ctc.insa.gov.et	GET	/api/roles/student/tasks			200	1384...	JSON
18	https://ctc.insa.gov.et	GET	/api/roles/student/yearb...			200	1077	JSON
19	https://ctc.insa.gov.et	GET	/api/roles/announcement...			200	965	JSON
20	https://ws.prod.htb.s...	OPTI...	/pusher/app/239b8f4dc4...	✓		200	464	text
21	https://ws.prod.htb.s...	POST	/pusher/app/239b8f4dc4...	✓		204	429	
22	https://app.notion.com	POST	/api/v3/getAssets.JsonV2	✓		200	756	JSON
23	https://ctc.insa.gov.et	GET	/api/roles/student/yearb...			200	1077	JSON
24	https://ctc.insa.gov.et	GET	/api/roles/student/tasks			200	1384...	JSON
25	https://ctc.insa.gov.et	GET	/api/roles/announcement...			200	965	JSON

Request

Pretty Raw Hex

```

9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 21
11 Origin:
12 https://0aa300b4033c91be82011a68006e0053.web-securi
13 ty-academy.net
14 Sec-Fetch-Dest: empty
15 Sec-Fetch-Mode: cors
16 Sec-Fetch-Site: same-origin
17 Priority: u=0
18 Te: trailers
19 Connection: keep-alive
20 productid=1&storeId=1

```

Response

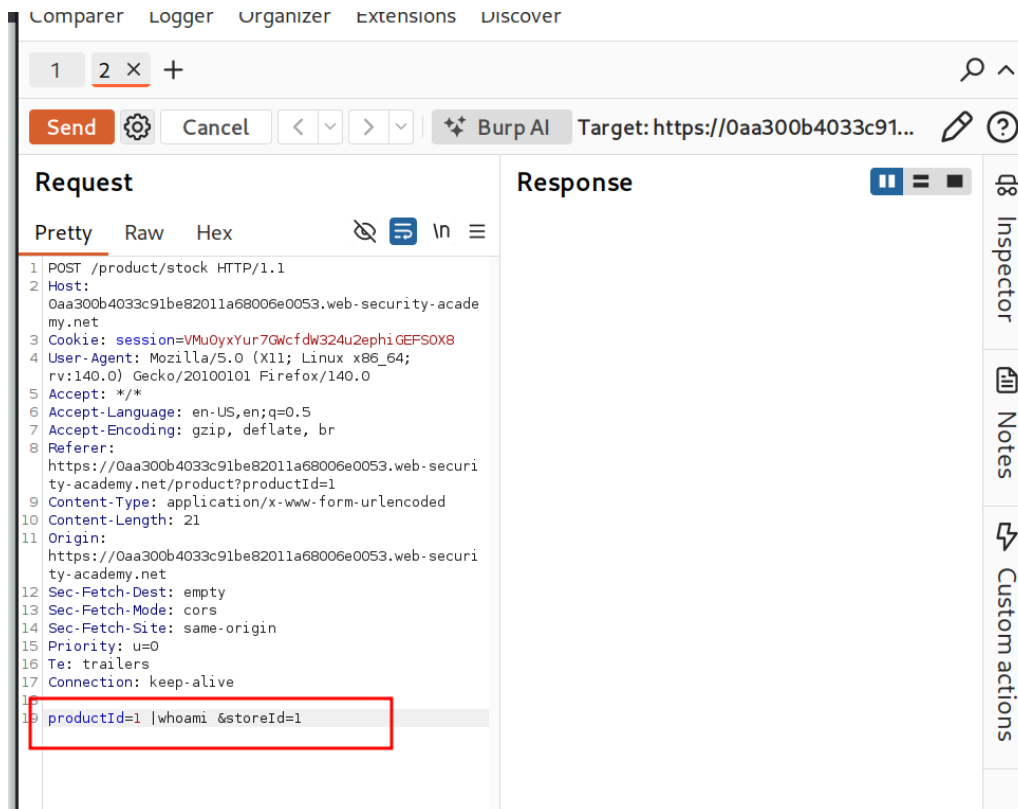
Pretty Raw Hex <Re...

```

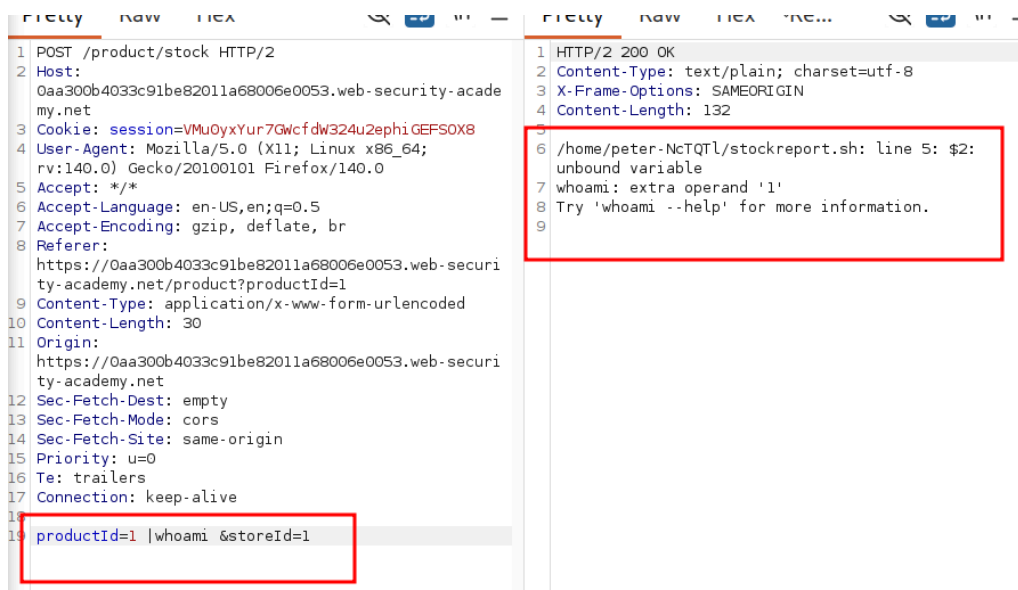
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3
5
6 62
7

```

then we will edit at StoredID wich is previously 1 to execute the follwoing shell command "whoami"



then observe the output



so we got our gold username "peter-NcTQTL"

